

PUBLIC PROFESSIONAL BRIEF

Threat Surface and NIST CSF 2.0 Profile

Baseline threat modeling, cross-domain dependency analysis, and CSF 2.0 current-state profiling for NorthGrid Energy.

Prepared by	Bernard Boakye Appiah
Scenario organization	NorthGrid Energy - fictional Ontario critical infrastructure operator
Document type	Threat surface and framework baseline
Public disclosure	All content is sanitized and based on a fictional security assessment scenario.
Date	July 2026

Selected assessment metrics

6 CSF functions	3 Domains assessed	5 Priority actions
--------------------	-----------------------	-----------------------

Public disclosure note: NorthGrid Energy is a fictional scenario used to demonstrate professional cybersecurity assessment, governance, and risk communication skills. The content is sanitized for public review and does not contain proprietary or private operational data.

OVERVIEW

Purpose and Public Summary

This brief summarizes the baseline risk posture of NorthGrid Energy using a three-domain threat surface model and NIST Cybersecurity Framework 2.0. The purpose was to identify where cyber, physical, and supply chain weaknesses combine to create operational risk for a fictional electrical utility.

The work showed that NorthGrid had several shared gaps also seen in major real-world critical infrastructure incidents: weak remote-access controls, missing IT/OT segmentation, unreviewed vendor access, limited incident response planning, and incomplete software supply chain governance.

SCOPE

Scenario Profile

Attribute	Public scenario detail
Organization	NorthGrid Energy - fictional Ontario electrical utility.
Operations	Regional NOC, three remote substations, approximately 220 employees, 40 remote workers.
OT environment	GE Grid Solutions EMS on Windows Server 2016, connected to corporate IT through a single firewall.
IT environment	Microsoft 365, on-premises Active Directory, Cisco networking, Fortinet perimeter firewalls.
Supply chain	HVAC/BMS remote access, managed SOC provider, cloud backup vendor, and other primary vendors.
Starting posture	No risk appetite, no formal IR plan, MFA on M365 but not VPN, flat IT/OT network, weak NOC controls, no SBOM requirements.

THREAT MODEL

Three-Domain Threat Surface

The three-domain model was used because a critical infrastructure operator can experience physical or operational consequences from a cyber event, and cyber consequences from a physical or vendor access failure.

Domain	Threat vector	Likely actor	Possible consequence
Cyber	VPN compromise through stolen credentials or weak MFA coverage.	Ransomware affiliate or external attacker.	Remote access, lateral movement, and potential reachability toward EMS-supporting systems.
Cyber	Flat IT/OT traversal from compromised corporate system.	APT, ransomware affiliate, or insider.	OT visibility or availability risk if network paths are not segmented.
Cyber	Public-facing application or firewall vulnerability.	External attacker.	Initial access to perimeter or remote management services.
Physical	Shared floor access near NOC workstations.	Visitor, insider, contractor.	Unauthorized observation, USB insertion, or workstation tampering risk.
Physical	OT cabinet room without matching Tier 1 physical controls.	Insider or contractor.	Proximity to OT network infrastructure, patch panels, or terminals.
Supply chain	Persistent vendor VPN access without recent review.	Compromised vendor or negligent access owner.	Dormant access path into internal network.
Supply chain	No SBOM requirement in vendor contracts.	Vendor software or third-party dependency issue.	Unknown vulnerable components in software used by critical systems.

FRAMEWORK

NIST CSF 2.0 Baseline Profile

Function	Current profile	Evidence-based rationale	Priority gap
GOVERN	Low maturity	No documented risk appetite, no formal vendor risk program, no SBOM contract requirement.	No clear ownership for cyber risk appetite, accountability, and supplier expectations.
IDENTIFY	Low maturity	Asset and dependency visibility incomplete across IT, OT, remote sites, and vendors.	Incomplete understanding of what must be protected and how systems depend on each other.
PROTECT	Partial maturity	MFA exists for M365 but not VPN; flat IT/OT; active USB ports; vendor credentials persistent.	Remote access and segmentation weaknesses could allow compromise to spread.
DETECT	Developing	Managed SOC exists but OT visibility, vendor access monitoring, and NOC physical monitoring are limited.	Detection does not fully cover operational or vendor pathways.
RESPOND	Low maturity	No formal incident response plan or OT-specific ransomware/vendor compromise playbooks.	Unclear escalation and containment decisions during a fast-moving incident.
RECOVER	Low maturity	Cloud backup vendor exists, but recovery tests, RTO/RPO, and OT restoration procedures are not proven.	Recovery depends on untested processes and vendor availability.

RISK PATHS

Cross-Domain Dependencies

The highest-risk dependencies were the points where a weakness in one domain could create a consequential impact in another. These were treated as priority focus areas because they show how small gaps can combine into larger operational risk.

Dependency	Origin domain	Attack path summary	Impact domain
Remote access and flat network	Cyber	A stolen VPN or domain credential could allow internal access and movement toward EMS-supporting systems because segmentation is weak.	Cyber + OT availability
NOC physical access and USB exposure	Physical	A person with physical proximity to operational workstations could attempt USB insertion, credential capture, or observation.	Cyber compromise
Vendor access and BMS connectivity	Supply chain	A compromised or unmanaged vendor account could provide a trusted path into corporate or building systems.	Cyber + physical environment
Supplier software trust	Supply chain	A malicious or vulnerable update could bypass normal perimeter controls if vendor trust is assumed without verification.	Cyber + OT operations

INCIDENT LEARNING

Colonial Pipeline Lessons Applied

The Colonial Pipeline case was used as a comparison point because it shows how IT compromise, remote access weakness, and operational decision-making can affect critical infrastructure services. In this public brief, the lesson is not that NorthGrid is identical to Colonial Pipeline; the lesson is that mid-size critical infrastructure operators can share similar baseline weaknesses.

Colonial-style gap	Present in NorthGrid scenario?	NorthGrid-specific lesson
No MFA on VPN	Yes	Remote access must be protected as a high-risk entry path, not treated as a normal convenience service.
Weak IT/OT segmentation	Yes	Segmentation is necessary to stop IT compromise from becoming operational disruption.
No OT incident response plan	Yes	Response playbooks must define containment authority, communication flow, and operational decision criteria.

Colonial-style gap	Present in NorthGrid scenario?	NorthGrid-specific lesson
Vendor access not reviewed	Yes	Trusted third-party access must expire, be reviewed, and be limited by least privilege.
No SBOM requirement	Yes	Supplier software visibility is part of risk management, not only procurement paperwork.

RECOMMENDATIONS

Priority Actions from This Brief

- 1 Document cybersecurity risk appetite and assign an accountable security owner for governance decisions.
- 2 Require MFA on VPN, privileged accounts, and all vendor remote access paths.
- 3 Start an industrial DMZ design to reduce direct IT-to-OT reachability.
- 4 Create an inventory of critical assets, vendor dependencies, remote access paths, and operational data flows.
- 5 Launch supplier risk reviews and add SBOM/security attestation requirements to critical vendor contracts.